

AGENT workflow 静态扫描三期灵镜适配特性

1 特性概述[必需]

当前，行内 Agent 应用仍以 Workflow 编排形态为主，开发平台及资产格式逐步多元化。第一期已完成面向 Dify 平台、采用 YML (YAML) DSL 的工作流静态安全扫描能力；第二期进一步适配行内自研 AI 智能工厂、采用 JSON DSL 的工作流，形成针对两类工作流文件的解析及安全库匹配能力。现阶段两类能力已具备独立扫描基础，但仍缺少面向行内用户的统一服务入口和平台化使用方式。

本期特性聚焦既有 AGENT workflow 静态扫描能力向灵镜平台的适配接入。相较一期、二期，本期不重新建设底层扫描规则，而是将原有工具能力封装为灵镜内可访问的服务，承接一事通身份鉴权、文件上传、扫描任务触发、结果查询、报告预览和文件下载，使既有静态检测能力具备统一入口、统一流程和统一结果展示。

在业务流程上，用户上传工作流文件后，系统首先判断文件类型；JSON 文件进入 JSON 安全库匹配流程，YML 文件进入 YML 安全库匹配流程。匹配完成后，系统按照统一模板生成扫描报告，并完成文件及报告存储、任务埋点、报告预览和文件下载，形成面向灵镜平台的完整静态扫描服务链路。

本期仅完成静态扫描能力的灵镜适配。整体设计保留资产适配和服务接口扩展能力，为后续接入其他工作流 DSL，以及 Python、Java 等语言开发的高码 Agent 提供基础。

本期范围：静态能力迁移与灵镜适配，包括 JSON/YML 类型分流、安全库匹配、模板报告生成以及报告预览下载，不包含动态扫描。

2 关联专题衡量指标[按需]

本期可围绕平台接入、格式分流、结果一致性和报告交付设置衡量维度，具体量化目标结合灵镜联调和验收要求确认。

衡量维度	指标说明	建议判定方式
平台接入	既有工作流静态扫描能力能够通过灵镜统一入口使用。	菜单、鉴权、上传、扫描和报告访问链路全部可用。
格式分流	能够正确判断 JSON/YML 文件并路由至相应安全库。	两类样例均进入正确分支；异常文件提示明确。
结果一致性	灵镜服务化调用与原扫描能力的核心风险结果保持一致。	问题数量、等级、规则编号和证据位置可核对。
报告交付	匹配结果能够按统一模板生成并完成预览、下载和存储。	报告内容完整，预览与下载结果一致。
任务追踪	上传文件、扫描任务、报告文件及埋点信息形成关联。	能够按任务编号查询完整处理记录。

3 特性全景

3.1 特性全景描述[必需]

三期整体能力由灵镜平台接入、文件处理与格式分流、静态安全库匹配、报告生成与结果交付四个部分构成。平台接入负责菜单、身份与服务调用；文件处理负责上传、校验、类型判断和任务记录；静态扫描根据JSON/YML 分支复用既有安全库；结果服务按照统一模板生成报告，并提供存储、埋点、预览和下载能力。

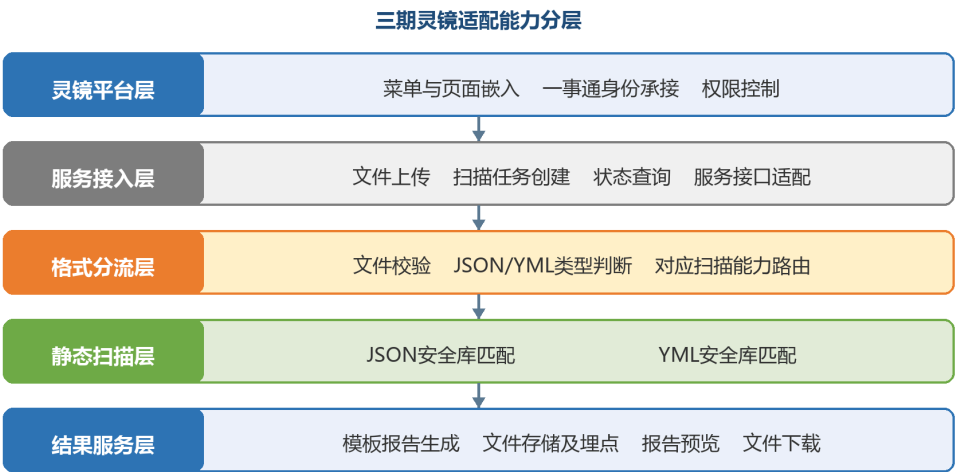


图3.1 三期灵镜适配能力分层图

序号	分类	功能简述
1	门户服务化接入	将既有静态扫描能力封装为灵镜内页面化服务，并统一上传、扫描、状态及报告接口。
2	灵镜平台嵌入	适配灵镜菜单、页面路由、布局及部署运行环境。
3	一事通身份承接	复用平台登录状态及权限信息，控制扫描和报告访问。
4	文件上传与校验	接收工作流文件并执行文件类型、大小、名称和路径校验。
5	文件类型判断	识别 JSON/YML 格式，并将文件分发至对应静态扫描流程。
6	JSON安全库匹配	调用第二期形成的 JSON 解析及规则匹配能力。
7	YML安全库匹配	调用第一期形成的 YML 解析及规则匹配能力。
8	模板报告生成	将两类扫描结果转换为结构一致的标准报告。
9	文件存储及埋点	关联保存上传文件、扫描任务、结果文件和必要过程信息。

序号	分类	功能简述
10	报告预览与下载	支持门户内查看扫描结论，并下载 HTML、PDF 或 JSON 报告。

3.2 业务流程图[必需]

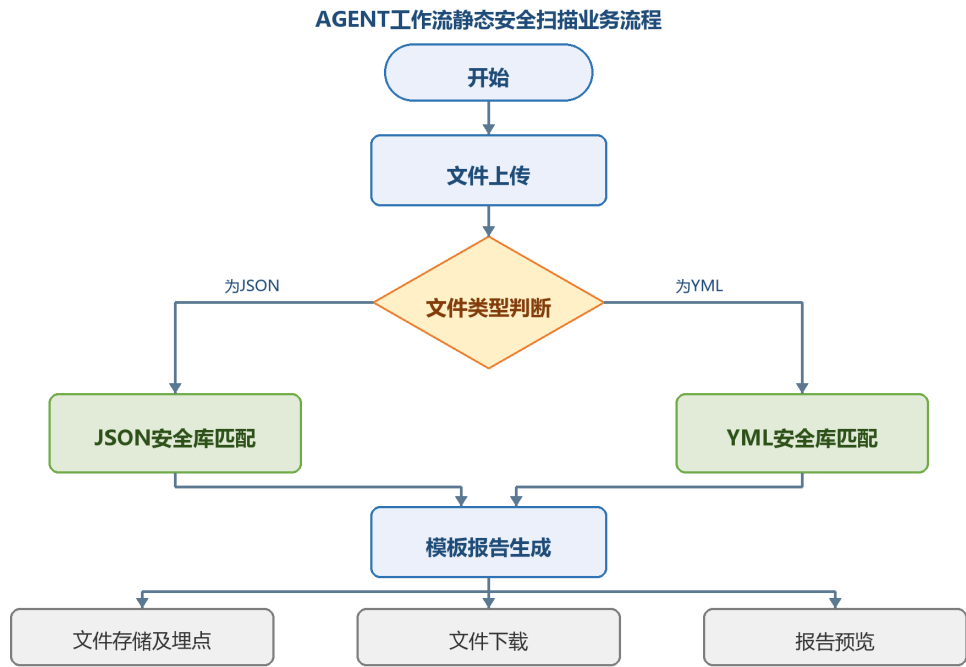


图3.2 AGENT工作流静态安全扫描业务流程图

用户通过灵镜入口上传待扫描文件，系统完成基础校验后判断文件类型。文件为 JSON 时调用 JSON 安全库匹配能力，文件为 YML 时调用 YML 安全库匹配能力；无法识别或不符合要求的文件不进入扫描流程，并返回明确提示。安全库匹配完成后，系统依据统一报告模板生成结果，并分别完成文件及报告存储、任务埋点、报告预览和文件下载。

3.3 原型说明[按需]

页面原型建议沿用已审批 Skill 灵镜适配特性的入口、任务状态和报告操作方式， workflow 扫描页面重点展示上传文件、格式判断结果、安全库匹配状态及报告操作。

页面/区域	主要展示内容	工作流适配要点
工作流安全扫描	文件上传、扫描说明、任务发起。	展示文件类型及 JSON/YML 分流结果。
扫描任务	任务编号、发起人、创建时间、当前状态、执行结果。	展示文件校验、安全库匹配和报告生成阶段。
报告预览	风险概览、问题明细、整改建议和工作流结构。	两类 DSL 使用统一模板和展示口径。
报告下载	下载 HTML、PDF、JSON 等报告文件。	下载文件与当前扫描任务保持一致。

4 特性说明

4.1 功能说明[必需]

4.1.1 功能描述

4.1.1.1 灵镜门户与身份接入能力

将一期、二期形成的工作流静态扫描能力由工具调用方式封装为灵镜内统一门户。门户承接灵镜菜单、路由、用户身份和权限控制，通过服务接口触发扫描并访问报告，不单独建设账号体系。

能力项	说明
门户嵌入	支持灵镜菜单、页面路由、布局和部署路径适配。
身份承接	复用一事通登录状态及用户标识，按平台权限控制扫描和报告访问。
服务封装	将文件上传、任务创建、状态查询、报告预览和下载封装为统一服务。
访问记录	记录任务发起人、发起时间、扫描文件、处理状态及报告访问情况。

4.1.1.2 文件上传、存储及埋点能力

门户接收 JSON 或 YML 工作流文件，并为每次上传建立独立扫描任务。后端保存上传文件及生成报告，记录文件标识、任务编号、处理状态和报告位置，满足隔离访问和过程追踪要求。

处理环节	功能要求
上传校验	校验文件类型、大小、名称和路径，拒绝目录穿越、非法后缀和异常结构。
任务隔离	按任务建立独立处理空间，避免不同用户或任务文件相互覆盖。
文件存储	分区保存上传文件和报告文件，并建立源文件与结果文件关联。
任务埋点	记录任务编号、发起人、文件类型、处理阶段、执行结果和报告位置。
生命周期	按照灵镜平台策略保留必要文件及任务记录，并清理临时处理文件。

4.1.1.3 文件类型判断与格式路由能力

系统在安全扫描前判断上传文件为 JSON 或 YML，并路由至对应的解析及安全库匹配能力。该环节仅负责格式识别和静态能力分发，不改变一期、二期既有规则逻辑。

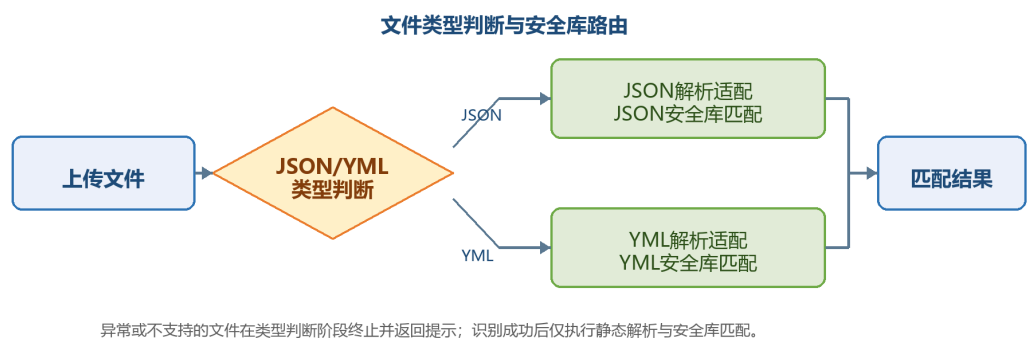


图4.1 文件类型判断与安全库路由图

判断结果	处理方式	异常要求
JSON	调用 AI 智能工厂 JSON 解析及 JSON 安全库匹配能力。	缺失关键字段时返回可定位的解析提示。
YML	调用 Dify YML 解析及 YML 安全库匹配能力。	结构不完整或版本不支持时返回明确提示。
无法识别	终止扫描，不进入任一安全库匹配流程。	说明不支持的格式或校验失败原因。

4.1.1.4 JSON与YML安全库匹配能力

安全库匹配是静态扫描的核心处理环节。系统根据文件类型调用对应的既有扫描能力，提取节点、参数、调用关系和配置内容，与相应安全规则进行匹配，形成包含规则编号、风险等级、证据位置、问题说明和整改建议的结构化结果。

扫描分支	复用能力	主要结果
JSON安全库匹配	复用第二期 AI 智能工厂 JSON DSL 解析、字段映射和静态规则分析能力。	JSON 工作流的规则命中、风险等级、问题证据及整改建议。
YML安全库匹配	复用第一期 Dify YML DSL 解析、节点识别和静态规则分析能力。	YML 工作流的规则命中、风险等级、问题证据及整改建议。
结果标准化	将两类扫描结果映射至统一字段和报告输入结构。	统一风险统计、问题明细和报告展示口径。

4.1.1.5 模板报告生成与结构展示能力

JSON 或 YML 安全库匹配完成后，系统将结构化结果交由统一模板生成报告。报告应覆盖风险概览、问题明细、证据位置、整改建议及必要的工作流结构信息，保证两类 DSL 在灵镜中的展示口径一致。

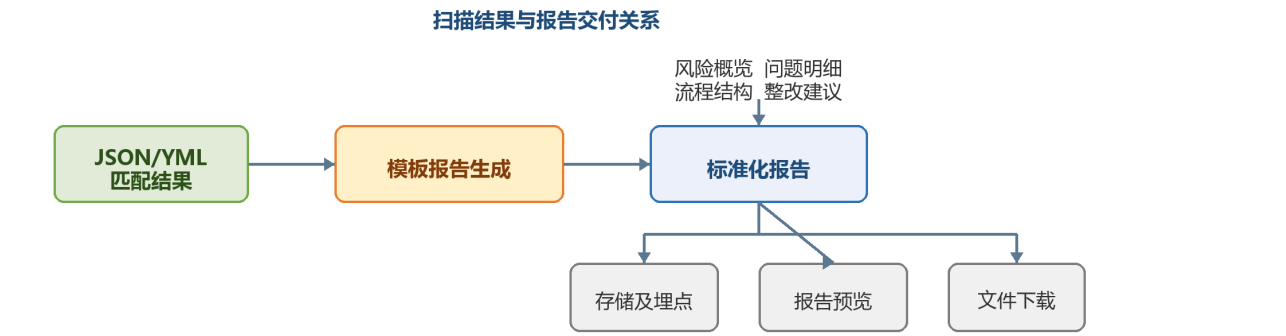


图4.2 扫描结果与报告交付关系图

报告内容	说明
扫描概览	展示文件名称、文件类型、扫描时间、整体等级和各等级风险数量。
问题明细	展示规则编号、风险等级、问题说明、证据位置和整改建议。
workflow 结构	根据已有解析结果展示关键节点及调用关系，辅助理解问题所在位置。
格式输出	支持生成 HTML、PDF、JSON 等报告，核心统计和结论保持一致。

4.1.1.6 报告预览与文件下载能力

扫描完成后，用户可在灵镜页面预览报告核心内容，也可下载完整报告用于归档、审批或后续系统处理。报告预览和下载使用同一任务结果，避免页面展示与文件内容不一致。

能力项	展示或处理内容
报告预览	展示扫描概览、风险分布、问题清单、风险详情和整改建议。
条件筛选	支持按风险等级、规则编号或节点等条件查看问题。
文件下载	提供 HTML、PDF、JSON 等已生成报告文件下载。
访问控制	依据一事通身份和任务归属校验预览及下载权限。
结果关联	报告文件、预览内容、源文件和任务编号保持关联。

4.1.2 验收标准

验收域	验收要点	结果要求
平台接入	灵镜菜单、页面路由及一事通身份能够正常承接。	授权用户可使用扫描及报告功能，未授权访问被拦截。
文件处理	上传校验、任务隔离、文件存储及任务埋点链路完整。	文件与任务关联正确，不发生越权访问或相互覆盖。

验收域	验收要点	结果要求
格式判断	JSON 与 YML 文件能够被正确识别并路由至对应安全库。	支持样例进入正确分支；异常文件提示明确。
安全库匹配	JSON/YML 既有静态规则能力能够通过灵镜服务正常调用。	核心扫描结果与一期、二期原能力保持一致。
报告生成	两类扫描结果均能按统一模板生成结构完整的报告。	风险统计、问题明细、证据和建议完整且口径一致。
预览与下载	门户可预览扫描结果，并下载对应任务的报告文件。	预览与下载内容一致，访问权限校验有效。

4.2 安全性评估[按需]

请评估是否涉及以下特性功能，如涉及，请勾选。

评估类别	涉及项	本期判断
用户认证与授权	平台登录状态、用户身份和菜单或报告访问权限。	☒ 涉及（复用灵镜及一事通能力）
文件与数据输入输出	workflow 文件上传、报告下载及扫描参数输入。	☒ 涉及
敏感数据处理	上传文件是否包含个人信息、三级及以上数据。	☐ 需由业务按实际上传内容确认
会话与审计	任务发起、文件处理、报告访问等过程记录。	☒ 涉及

涉及项应依据我行《应用系统安全需求规范》及灵镜平台现有安全要求落实；上传内容的数据等级、访问范围和留存期限需在线上确认。

4.3 非功能需求[按需]

类别	要求
兼容性	兼容既有 Dify YML 与 AI 智能工厂 JSON 样例，并能够识别不支持的文件。
可靠性	扫描任务状态可查询，失败原因明确，重试不覆盖其他任务文件及报告。
安全性	落实文件类型、大小和路径校验，以及任务隔离、访问控制和下载鉴权。
一致性	JSON/YML 两类结果使用统一报告字段，预览内容与下载文件保持一致。
可扩展性	保留新增资产适配器和扫描接口的能力，支持后续接入 Python/Java 高码 Agent。
性能	页面持续反馈任务状态；具体并发能力和处理时限在联调阶段确认。

4.4 涉及的系统/组件/功能清单[按需]

序号	系统/组件	本期职责或改造内容
1	LT80.01_smirror_mgt_backend	承载文件接收、类型判断、扫描能力路由、任务状态、报告及埋点数据服务。
2	LT80.01_smirror_frontend_react	新增 workflow 安全扫描、任务状态、报告预览和下载相关页面。
3	既有 JSON/YML 静态扫描能力	作为扫描引擎被服务化调用，保持既有规则和核心结果一致。
4	COS / file_record 等存储能力	分区保存上传文件与报告，记录文件元数据、任务关联和访问位置。
5	灵镜平台 / 一事通	提供统一入口、菜单路由、身份认证、权限承接及部署运行环境。
6	workflow 扫描任务及埋点数据	保存任务状态、文件类型、结果摘要、报告位置和必要审计信息。

5 特性投入估算[按需]

待结合灵镜平台接口联调范围、前后端页面工作量、存储改造方式及 JSON/YML 回归测试集规模进一步评估。

6 期望上线时间[必需]

2026-09（待确认）